

# Zentraler Log-Service

Autor: Martin Smock

Projekt: DigiSanté Architektur

Ausgabe: 0.9

Datum: 17. Februar 2025

## Inhalt:

|           |                                      |           |
|-----------|--------------------------------------|-----------|
| <b>1</b>  | <b>Einführung und Ziele.....</b>     | <b>3</b>  |
| 1.1       | Aufgabenstellung.....                | 3         |
| 1.2       | Zielstellung.....                    | 3         |
| 1.2.1     | Abgrenzung.....                      | 4         |
| 1.3       | Qualitätsziele .....                 | 4         |
| 1.4       | Stakeholder .....                    | 5         |
| <b>2</b>  | <b>Randbedingungen .....</b>         | <b>5</b>  |
| 2.1       | Schutzbedarf .....                   | 5         |
| <b>3</b>  | <b>Kontextabgrenzung .....</b>       | <b>7</b>  |
| 3.1       | Fachlicher Kontext .....             | 7         |
| 3.2       | Technischer Kontext .....            | 8         |
| <b>4</b>  | <b>Lösungsstrategie .....</b>        | <b>9</b>  |
| <b>5</b>  | <b>Bausteinsicht.....</b>            | <b>10</b> |
| 5.1.1     | Identity und Access Management ..... | 10        |
| 5.1.2     | Log Repository .....                 | 11        |
| 5.1.3     | Backup System.....                   | 12        |
| 5.2       | Ebene 2 .....                        | 13        |
| 5.3       | Ebene 3 .....                        | 13        |
| <b>6</b>  | <b>Laufzeitsicht .....</b>           | <b>13</b> |
| <b>7</b>  | <b>Verteilungssicht.....</b>         | <b>13</b> |
| <b>8</b>  | <b>Querschnitt Konzepte .....</b>    | <b>13</b> |
| <b>9</b>  | <b>Architekturentscheide .....</b>   | <b>13</b> |
| <b>10</b> | <b>Qualitätsanforderungen .....</b>  | <b>14</b> |
| 10.1      | Qualitätsbaum.....                   | 14        |
| 10.2      | Qualitätsszenarien.....              | 14        |
| 10.3      | Risiken und technische Schulden..... | 14        |
| <b>11</b> | <b>Glossar .....</b>                 | <b>15</b> |
| <b>12</b> | <b>Anhang.....</b>                   | <b>16</b> |
| 12.1      | Log Einträge.....                    | 16        |
| 12.2      | Abschätzung Datenvolumen.....        | 16        |
| 12.3      | Beispiel FHIR Audit Event .....      | 16        |

# 1 Einführung und Ziele

## 1.1 Aufgabenstellung

Es soll ein zentraler Dienst entworfen werden, welche von allen Applikationen des BAG und den Datenraum Gesundheit (Swiss HDS) für die Protokollierung gemäss der «Verordnung für den Datenschutz» (Datenschutzverordnung, DSV) vom 31. August 2022 genutzt werden kann.

Die Datenschutzverordnung stellt in Artikel 4 die folgenden architekturelevanten Anforderungen an die Protokollierung der Bearbeitung von Personendaten durch Bundesorgane:

- Art. 4, Abs. 2: Das verantwortliche Bundesorgan und sein Auftragsbearbeiter protokollieren bei der automatisierten Bearbeitung von Personendaten zumindest das Speichern, Verändern, Lesen, Bekanntgeben, Löschen und Vernichten der Daten.
- Art. 4, Abs. 3: Bei Personendaten, welche allgemein öffentlich zugänglich sind, sind zumindest das Speichern, Verändern, Löschen und Vernichten der Daten zu protokollieren.
- Art. 4, Abs. 4: Die Protokollierung muss Aufschluss geben über die Identität der Person, die die Bearbeitung vorgenommen hat, die Art, das Datum und die Uhrzeit der Bearbeitung sowie gegebenenfalls die Identität der Empfängerin oder des Empfängers der Daten.
- Art. 4, Abs. 5: Die Protokolle müssen während mindestens einem Jahr getrennt vom System, in welchem die Personendaten bearbeitet werden, aufbewahrt werden. Sie dürfen ausschliesslich den Organen und Personen zugänglich sein, denen die Überprüfung der Anwendung der Datenschutzvorschriften oder die Wahrung oder Wiederherstellung der Vertraulichkeit, Integrität, Verfügbarkeit und Nachvollziehbarkeit der Daten obliegt, und dürfen nur für diesen Zweck verwendet werden.

## 1.2 Zielstellung

Protokolldaten von IT Systemen lassen sich grob in 3 Kategorien einstufen:

- Application Logs – Protokolldaten einzelner Applikationen zum Zwecke der Fehlererkennung und Behebung von Applikationen durch die Entwickler und Administratoren. Application Logs sind typischerweise unstrukturiert und werden in lokalen Filesystemen abgelegt. Die Anzahl und Granularität der Application Logs ist spezifisch für die Applikationen. Application Logs werden typischerweise nur wenige Tage oder Stunden aufbewahrt.
- System Logs – Protokolldaten für die Überwachung des Betriebs von der Applikationslandschaften und Erkennen von anormalen Mustern (z.B.: DDoS Angriffe). System Logs sind strukturiert und werden in speziellen Repositories (SIEM – Security Information and Event Management) abgelegt. Die Anzahl und Granularität der System Logs ist durch die Anforderungen der Überwachung bestimmt. System Logs werden typischerweise nur wenige Tage aufbewahrt.

- Audit Trail - Protokolldaten von Applikationen zum Zwecke der Rückverfolgung von nicht autorisierten Zugriffen auf Personendaten und damit verbundenen Verletzungen des Datenschutzes. Application Trails sind typischerweise strukturiert und werden in speziellen Repositories (Audit Repository) abgelegt. Die Anzahl, Granularität und die Dauer der Aufbewahrung der Audit Trails richtet sich nach den gesetzlichen Anforderungen.

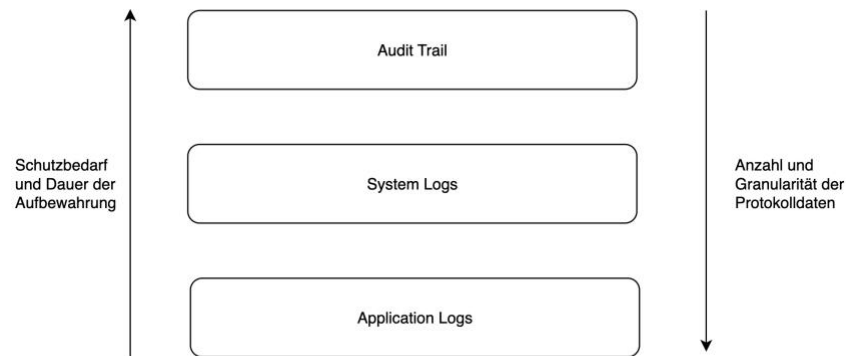


Abbildung 1: Kategorien von Protokolldaten

Der in diesem Dokument spezifizierte Log Service soll Applikationen ermöglichen die Anforderungen aus der Datenschutzverordnung Art. 4 durch Nutzung des Service zu erfüllen. Der Log Service ist daher ein Service der Kategorie Audit Trail.

### 1.2.1 Abgrenzung

Der Log Service soll Protokolldaten von Applikationen zum Zwecke der Rückverfolgung von nicht autorisierten Zugriffen auf Personendaten und damit verbundenen Verletzungen des Datenschutzes speichern. Die Zwecke von System Logs und Application Logs zur Überwachung des Betriebs und der Fehlersuche sind nicht kompatibel zum vorgesehenen Zweck des Log Service. Die Anforderungen an die Systeme zur Speicherung und Analyse von System und Application Logs müssen durch andere Services abgedeckt werden.

### 1.3 Qualitätsziele

| <b>Ziel</b>                  | <b>Beschreibung</b>                                                                                   | <b>Anmerkungen</b>                                                                                       |
|------------------------------|-------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Verfügbarkeit                | Der Service muss 7*24 verfügbar sein.                                                                 | Der Service soll von allen Applikationen des BAG und im Swiss HDS rund um die Uhr genutzt werden können. |
| Sicherheit                   | Der Service muss gegen unberechtigte Lese und Schreibzugriffe nach DSV Art. 4, Abs. 5 geschützt sein. |                                                                                                          |
| Integrität und Authentizität | Der Service muss die Integrität und Authentizität der Protokolldaten schützen.                        |                                                                                                          |

|                |                                                                                                                             |                                                                                                                                                                                      |
|----------------|-----------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Datenvolumen   | Der Dienst muss die anfallenden Datenmengen verarbeiten können.                                                             | Als Faustregel gilt dabei: 1 GB Datenvolumen entspricht ca. 2 Millionen Protokolleinträgen.                                                                                          |
| Skalierbarkeit | Der Dienst muss so skaliert werden können, dass er von zukünftigen neuen BAG und Swiss HDS Anwendungen genutzt werden kann. |                                                                                                                                                                                      |
| Performanz     | Der Service muss eine ausreichend hohe Performance für Schreiboperationen haben.                                            | Alle BAG und Swiss HDS Anwendungen, welche Personendaten bearbeiten, müssen die Bearbeitung protokollieren können, ohne dass der Betrieb der Anwendungen merkbar eingeschränkt wird. |
|                |                                                                                                                             |                                                                                                                                                                                      |

#### 1.4 Stakeholder

| <b>Stakeholder</b>             | <b>Anmerkungen</b>                                                                                                                                                                      |
|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Shared Service Architektur     | Verantwortlich für die Entwicklung und den Betrieb von Infrastrukturdiensten für den Datenraum Gesundheit                                                                               |
| Shared Service Common Services | Verantwortlich für die Entwicklung und den Betrieb von Services, welche von allen Anwendungen des BAG und für den Datenraum Gesundheit genutzt werden können oder müssen.               |
| Programm DigiSanté             | Verantwortlich für die Entwicklung und den Betrieb von Services im Rahmen des Programms                                                                                                 |
| Fachabteilungen des BAG        | Alle Abteilungen, welche aktuell oder zukünftig Applikationen zur Bearbeitung von Personendaten entwickeln und betreiben oder durch Auftragsbearbeiter entwickeln und betreiben lassen. |
| Fachabteilungen BFS            | Alle Abteilungen, welche aktuell oder zukünftig Applikationen zur Bearbeitung von Personendaten entwickeln und betreiben oder durch Auftragsbearbeiter entwickeln und betreiben lassen. |
|                                |                                                                                                                                                                                         |

## 2 Randbedingungen

### 2.1 Schutzbedarf

Je nach ausgeführter Aktion enthalten die Protokolleinträge Personendaten oder besonders schützenswerte Personendaten der betroffenen Personen. So enthalten die Protokolleinträge von schreibenden Zugriffen typischerweise alle Daten, welche von der Applikation durch die Transaktion geändert werden.

Der Schutzbedarf des Log Services entspricht damit dem höchsten Schutzbedarf aller Applikationen, welche den Log Service zur rechtskonformen Protokollierung nutzen.

### 3 Kontextabgrenzung

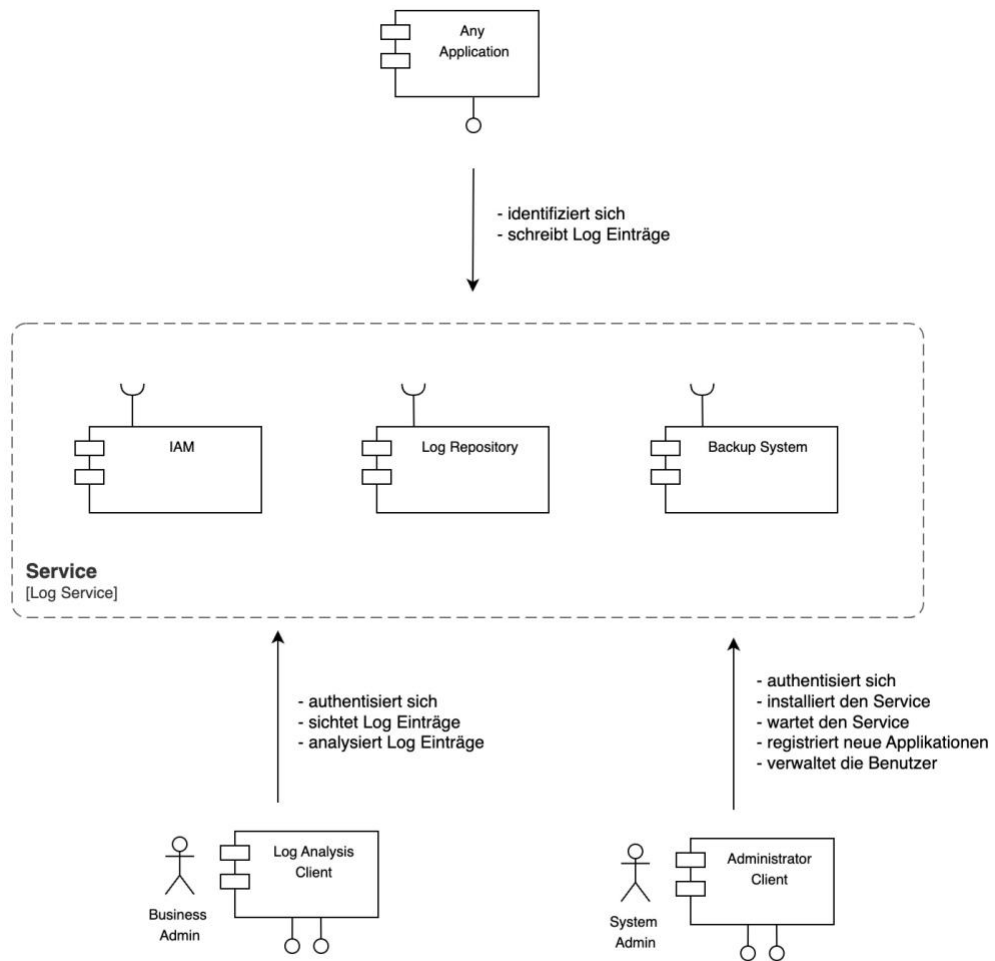


Abbildung 2: Kontextdiagramm des Service

#### 3.1 Fachlicher Kontext

| <b>Service</b> | <b>Kontext</b>                                                                                                                           | <b>Anmerkungen</b> |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| IAM Service    | Authentisierung und Autorisierung der Fach-Administratoren für die Sichtung und Analyse von potenziellen Verletzungen des Datenschutzes. |                    |
|                | Authentisierung und Autorisierung der System-Administratoren für Installation und Wartung des Service.                                   |                    |
|                | Authentisierung von Fachapplikationen und Autorisierung zum Speichern von Protokolldaten.                                                |                    |

|                |                                                                                                                                                                                      |                                                                                            |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Log Repository | Implementierung von Schnittstellen zur Speicherung von Protokolldaten durch die Fachapplikationen, sowie Funktionen für das automatische Löschen nach Ablauf der Aufbewahrungsdauer. | Der Zugriff auf das Repository erfordert eine Lese bzw. Schreibberechtigung durch das IAM. |
| Backup System  | Funktionen zur Erstellung von Backups der Protokolldaten zum Zwecke der Wiederherstellung nach Systemausfällen.                                                                      | Der Zugriff auf das Backup System ist über das IAM abgesichert.                            |
|                |                                                                                                                                                                                      |                                                                                            |

### 3.2 Technischer Kontext

| <b>Service</b> | <b>Schnittstellen</b>                                                                           | <b>Anmerkungen</b>                                                                                                     |
|----------------|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| IAM            | Autorisierung von Applikationen, welche für die Speicherung von Protokolldaten berechtigt sind. | Autorisierung nach dem OAuth Standard                                                                                  |
|                | Authentisierung und Autorisierung von Fach-Administratoren.                                     | Authentisierung und Autorisierung nach Open ID Connect und OAuth Standard                                              |
|                | Authentisierung und Autorisierung von System-Administratoren.                                   | Nutzung der Authentisierung und Autorisierung auf der Kontrollebene (Control Plane)                                    |
| Log Repository | REST Interface zur Speicherung von Protokolleinträgen                                           | Für Applikationen, welche zur Speicherung von Protokolleinträgen registriert sind.                                     |
|                | REST Interface zur Abfrage von Protokolleinträgen und Anzeige im Log Analysis Client            | Die Abfrage ist über das IAM geschützt und nur Benutzern der Rolle Fach-Administrator möglich.                         |
|                | Funktionen zum Export von Daten nach Filterkriterien zwecks Beweissicherung                     | Die Abfrage ist über das IAM geschützt und nur Benutzern der Rolle Fach-Administrator möglich.                         |
|                | CLI oder anderes Interface zur Administration                                                   | Der Zugriff auf der Control Plane ist über das IAM geschützt und nur Benutzern der Rolle System-Administrator möglich. |
| Backup System  | CLI oder anderes Interface zur Administration                                                   | Der Zugriff auf der Control Plane ist über das IAM geschützt und nur Benutzern der Rolle System-Administrator möglich. |
|                |                                                                                                 |                                                                                                                        |



## 4 Lösungsstrategie

| <b>Strategie</b>             | <b>Anmerkungen</b>                                                                                                                                                                                                                                                                                          |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Internationale Standards     | Die Lösung nutzt international etablierte Standards                                                                                                                                                                                                                                                         |
| Parallelisierung             | Die Lösung soll für eine horizontale Skalierung vorbereitet sein, da die zukünftigen Applikationen und die daraus abgeleitete Last zum Designzeitpunkt nicht abgeschätzt werden kann.                                                                                                                       |
| Integrität und Authentizität | Die Lösung unterstützt Methoden zur Sicherstellung der Integrität und Authentizität von Log Einträgen, so dass Log Einträge auf einem gewissen Niveau gegen Fälschung und Veränderung geschützt sind. Das erforderliche Sicherheitsniveau und daraus abgeleiteten Massnahmen sind aktuell nicht festgelegt. |
| Protokolleinträge            | Die Protokolleinträge enthalten nur die per Gesetz geforderten Informationen um das Datenvolumen zu minimieren.                                                                                                                                                                                             |
|                              |                                                                                                                                                                                                                                                                                                             |

## 5 Bausteinsicht

### 5.1.1 Identity und Access Management

#### 5.1.1.1 Zweck und Verantwortung

Der IAM Service erfüllt die folgenden Aufgaben:

- Autorisierung der Applikationen welche Log Einträge schreiben können.
- Sichere Authentifizierung und Autorisierung der Fach-Administratoren für den lesenden Zugriff auf die Protokolldaten.
- Sichere Authentifizierung und Autorisierung der System-Administratoren für die Administration des Log Repositories und dem Backup System.

#### 5.1.1.2 Abgrenzung

Die Anforderungen zur Authentisierung und Autorisierung von System-Administratoren werden typischerweise durch das IAM der Control Plane (z.B. Active Directory des Cloud Providers) abgedeckt.

#### 5.1.1.3 Schnittstellen

| <b>Schnittstellen</b> | <b>Kontext</b>                                                                   | <b>Anmerkung</b>                                                                                         |
|-----------------------|----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Open ID Connect       | Authentisierung von Benutzern der Rolle Fach-Administrator                       | Entfällt, wenn AGOV als Identity Provider genutzt wird                                                   |
|                       | Authentisierung von Benutzern der Rolle System-Administrator                     | Entfällt, wenn die Authentisierung der Control Ebene des Cloud Service Providers (z.B. BIT) genutzt wird |
| OAuth 2.1             | Autorisierung von lesenden Zugriffen durch Benutzer der Rolle Fach-Administrator |                                                                                                          |
|                       | Autorisierung von Zugriffen durch Benutzer der Rolle System-Administrator        | Entfällt, wenn die Autorisierung der Control Ebene des Cloud Service Providers (z.B. BIT) genutzt wird   |
|                       | Autorisierung der Applikationen welche Log Einträge schreiben können             |                                                                                                          |
|                       |                                                                                  |                                                                                                          |

#### 5.1.1.4 Qualitäts- und Leistungsanforderungen

| <b>Anforderungen</b> | <b>Kontext</b>                    | <b>Anmerkung</b>                              |
|----------------------|-----------------------------------|-----------------------------------------------|
| Hochverfügbar        | Authentisierung und Autorisierung | Der Service muss 7*24 Stunden verfügbar sein. |
|                      |                                   |                                               |

|  |  |  |
|--|--|--|
|  |  |  |
|--|--|--|

#### 5.1.1.5 Offene Punkte

Keine.

#### 5.1.2 Log Repository

##### 5.1.2.1 Zweck und Verantwortung

Das Log Repository erfüllt die folgenden Aufgaben:

- Revisionssichere Speicherung der Protokolldaten der Applikationen.
- Funktionen zum Löschen von Protokolldaten nach Ablauf der gesetzlichen Aufbewahrungsfrist.

##### 5.1.2.2 Abgrenzung

Keine.

##### 5.1.2.3 Schnittstellen

| <b>Schnittstellen</b>                                                                | <b>Kontext</b>                    | <b>Anmerkung</b>                                                                                                       |
|--------------------------------------------------------------------------------------|-----------------------------------|------------------------------------------------------------------------------------------------------------------------|
| REST Interface zur Speicherung von Protokolleinträgen                                | Protokollierung                   | Für Applikationen, welche zur Speicherung von Protokolleinträgen registriert sind.                                     |
| REST Interface zur Abfrage von Protokolleinträgen und Anzeige im Log Analysis Client | Auswertung                        | Die Abfrage ist über das IAM geschützt und nur Benutzern der Rolle Fach-Administrator möglich.                         |
| Funktionen zum Export von Daten nach Filterkriterien zwecks Beweissicherung          | Beweissicherung                   | Die Abfrage ist über das IAM geschützt und nur Benutzern der Rolle Fach-Administrator möglich.                         |
| CLI oder anderes Interface zur Administration                                        | Installation, Wartung und Betrieb | Der Zugriff auf der Control Plane ist über das IAM geschützt und nur Benutzern der Rolle System-Administrator möglich. |
|                                                                                      |                                   |                                                                                                                        |

##### 5.1.2.4 Qualitäts- und Leistungsanforderungen

| <b>Anforderungen</b> | <b>Kontext</b>  | <b>Anmerkung</b>                                                                                                                             |
|----------------------|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Hochverfügbar        | Protokollierung | Der Service muss 7*24 Stunden verfügbar sein, damit Applikationen im laufenden Betrieb ohne wesentliche Verzögerungen protokollieren können. |

|               |                 |                                                                                                                                                                                                                        |
|---------------|-----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Speicherplatz | Protokollierung | Der Service muss kontinuierlich an Veränderungen des Speicherbedarfs angepasst werden können. Es gilt die Faustregel: 1 GB pro ca. 2 Millionen Log Einträge.                                                           |
| Authentizität | Protokollierung | Die Log Einträge müssen über den gesamten Aufbewahrungszeitraum mit einer definierten Sicherheit eindeutig den Applikationen zugeordnet werden können.                                                                 |
| Integrität    | Protokollierung | Die Integrität der Log Einträge muss über den gesamten Aufbewahrungszeitraum mit einer definierten Sicherheit gewährleistet werden können. Insbesondere müssen Änderungen nach der Übermittlung erkannt werden können. |
|               |                 |                                                                                                                                                                                                                        |

#### 5.1.2.5 Offene Punkte

- Sicherheitsniveau der Authentizität und Integrität der Log Einträge und die daraus abgeleiteten Massnahmen (z.B. elektronische Signatur für die höchste Sicherheitsstufe).
- Format und Attribute der Log Einträge bei der Übermittlung.

### 5.1.3 Backup System

#### 5.1.3.1 Zweck und Verantwortung

Der Backup Service erfüllt die folgenden Aufgaben:

- Erstellung und Verwaltung von Backups der Protokolldaten zum Zwecke der Wiederherstellung des Log Repository nach Systemausfällen

#### 5.1.3.2 Abgrenzung

Der Backup Service dient nur dem oben genannten Zweck und die Verwaltung des Backup Systems muss das Löschen der Backups nach Erfüllung des Zwecks sicherstellen.

#### 5.1.3.3 Schnittstellen

| <b>Schnittstellen</b>                         | <b>Kontext</b>                    | <b>Anmerkung</b>                                                                                                       |
|-----------------------------------------------|-----------------------------------|------------------------------------------------------------------------------------------------------------------------|
| CLI oder anderes Interface zur Administration | Installation, Wartung und Betrieb | Der Zugriff auf der Control Plane ist über das IAM geschützt und nur Benutzern der Rolle System-Administrator möglich. |
|                                               | Verwaltung der Backups            | Der Zugriff auf der Control Plane ist über das IAM geschützt und nur Benutzern der Rolle System-Administrator möglich. |

|  |  |  |
|--|--|--|
|  |  |  |
|--|--|--|

#### 5.1.3.4 Qualitäts- und Leistungsanforderungen

| <b>Anforderungen</b> | <b>Kontext</b> | <b>Anmerkung</b>                                                                                                                                                                                                       |
|----------------------|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Speicherplatz        | Backup         | Der Service muss kontinuierlich an Veränderungen des Speicherbedarfs angepasst werden können. Es gilt die Faustregel: 1 GB pro ca. 2 Millionen Log Einträge.                                                           |
| Authentizität        | Aufbewahrung   | Die Log Einträge müssen über den gesamten Aufbewahrungszeitraum mit einer definierten Sicherheit ein-eindeutig den Applikationen zugeordnet werden können.                                                             |
| Integrität           | Aufbewahrung   | Die Integrität der Log Einträge muss über den gesamten Aufbewahrungszeitraum mit einer definierten Sicherheit gewährleistet werden können. Insbesondere müssen Änderungen nach der Übermittlung erkannt werden können. |
| Verschlüsselung      | Aufbewahrung   | Backups müssen verschlüsselt abgespeichert werden.                                                                                                                                                                     |
|                      |                |                                                                                                                                                                                                                        |

#### 5.1.3.5 Offene Punkte

Keine.

#### 5.2 Ebene 2

Wird im Rahmen der Projektinitialisierung ergänzt.

#### 5.3 Ebene 3

Wird im Rahmen der Projektinitialisierung ergänzt.

#### 6 Laufzeitsicht

Wird im Rahmen der Projektinitialisierung ergänzt.

#### 7 Verteilungssicht

Wird im Rahmen der Projektinitialisierung ergänzt.

#### 8 Querschnitt Konzepte

Wird im Rahmen der Projektinitialisierung ergänzt.

#### 9 Architekturentscheide

| <b><i>Alternative</i></b> | <b><i>Entscheid</i></b> |
|---------------------------|-------------------------|
|                           |                         |

## 10 Qualitätsanforderungen

### 10.1 Qualitätsbaum

Wird im Rahmen der Projektinitialisierung ergänzt.

### 10.2 Qualitätsszenarien

Wird im Rahmen der Projektinitialisierung ergänzt.

### 10.3 Risiken und technische Schulden

Wird im Rahmen der Projektinitialisierung ergänzt.

## 11 Glossar

| Begriff |                                                                                                                                                                                                                                                               |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SIEM    | Allgemeine Bezeichnung für Security Information and Event Management Systeme, welche Systemprotokolle speichern, analysieren und ggfs. Alarme auslösen. SIEM bieten typischerweise Cockpits zur manuellen Analyse mit angepassten Filter- und Suchfunktionen. |
| CLI     | Command Line Interface – Interface zur Ausführung von Befehlen auf der Konsole. CLI werden typischerweise für Funktionen zur Administration von Softwaresystemen angeboten und durch Administratoren genutzt.                                                 |
| MAC     | Message Authentication Code – Methode zur Prüfung der Authentizität und Integrität von ausgetauschten Nachrichten.                                                                                                                                            |
|         |                                                                                                                                                                                                                                                               |

## 12 Anhang

### 12.1 Log Einträge

Log Einträge sind idealerweise kompakt und nutzen nur die zum Zweck benötigten Attribute, z.B.:

| <b>Attribut</b> | <b>Format</b>                  | <b>Kontext</b>                                                                                                           |
|-----------------|--------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| version         | String (UTF-8)                 | Verweis auf die Version der Spezifikation der Log Einträge                                                               |
| timestamp       | String (ISO-8601)              | Zeitstempel                                                                                                              |
| host            | String (UTF-8)                 | OID der Applikation, welche den Protokolleintrag sendet                                                                  |
| user_name       | String (UTF-8)                 | Name des Benutzers, welcher die protokollierte Aktion ausgelöst hat                                                      |
| user_id         | String (UTF-8)                 | ID des Benutzers, welcher die protokollierte Aktion ausgelöst hat                                                        |
| action          | Coded Value                    | Schlüsselwort für die protokollierte Aktion (Lesen, Schreiben, ...).                                                     |
| query           | String (UTF-8), Base64 encoded | Informationen zur protokollierten Funktion, welcher je nach Aktion Personendaten der Betroffenen Personen enthalten kann |
| hash            | String (UTF-8)                 | Hashwert, MAC oder Signatur des Protokolleintrags                                                                        |

### 12.2 Abschätzung Datenvolumen

| <b>Datensatz</b>          | <b>Kontext</b> | <b>Volumen (typisch)</b> |
|---------------------------|----------------|--------------------------|
| Protokoll der Bearbeitung |                | 0.3 bis 0.5 kB           |
|                           |                |                          |

### 12.3 Beispiel FHIR Audit Event

Der FHIR Standard definiert mit der Audit Event Ressource einen Standard für Log Einträge im Gesundheitswesen. FHIR Audit Event Ressourcen sind weniger kompakt als andere Standards, insb. durch die Konvention URL als ID von Code Systemen zu verwenden.

Im Folgenden ist ein Beispiel für einen Log Eintrag für eine Query nach FHIR Ressourcen (ca. 2.2 kB) angegeben:

```
{
  "resourceType" : "AuditEvent",
  "id" : "example-search",
  "category" : [{
    "coding" : [{
```



```

    "system" : "http://terminology.hl7.org/CodeSystem/audit-event-type",
    "code" : "rest",
    "display" : "Restful Operation"
  ]]
}],
"code" : {
  "coding" : [{
    "system" : "http://hl7.org/fhir/restful-interaction",
    "code" : "search",
    "display" : "search"
  }]
},
"action" : "E",
"recorded" : "2015-08-22T23:42:24Z",
"outcome" : {
  "code" : {
    "system" : "http://terminology.hl7.org/CodeSystem/audit-event-outcome",
    "code" : "0",
    "display" : "Success"
  }
},
"agent" : [{
  "type" : {
    "coding" : [{
      "system" : "http://terminology.hl7.org/CodeSystem/extra-security-role-type",
      "code" : "humanuser",
      "display" : "human user"
    }]
  }
},
"who" : {
  "identifier" : {
    "value" : "382a60ec-9bed-447c-84b9-54509b54369d"
  },
  "display" : "Grahame Grieve"
},
"requestor" : true
},
{
  "extension" : [{
    "url" : "http://hl7.org/fhir/StructureDefinition/auditevent-AlternativeUserID",
    "valueIdentifier" : {
      "type" : {
        "text" : "process ID"
      },
      "value" : "6580"
    }
  }]
},
"type" : {

```

```

    "coding" : [{
      "system" : "http://dicom.nema.org/resources/ontology/DCM",
      "code" : "110153",
      "display" : "Source Role ID"
    }]
  },
  "who" : {
    "identifier" : {
      "system" : "urn:oid:2.16.840.1.113883.4.2",
      "value" : "2.16.840.1.113883.4.2"
    }
  },
  "requestor" : false,
  "networkString" : "Workstation1.ehr.familyclinic.com"
}],
"source" : {
  "observer" : {
    "display" : "hl7connect.healthintersections.com.au"
  },
  "type" : [{
    "coding" : [{
      "system" : "http://terminology.hl7.org/CodeSystem/security-source-type",
      "code" : "3",
      "display" : "Web Server"
    }]
  }]
},
"entity" : [{
  "role" : {
    "coding" : [{
      "system" : "http://terminology.hl7.org/CodeSystem/object-role",
      "code" : "24",
      "display" : "Query"
    }]
  },
  "query" :
"aHR0cDovL2ZoaXItZGV2LmhlYWx0aGludGVyc2VjdGlvdnMuY29tLmF1L29wZW4vRW5jb3VudGVyP3BhcnRpdY2lwYW50PTEz"
}]
}

```